NOVATECH SOLUTIONS

NIST SP 800-53 Security Control Assessment

Final Technical Assessment Report | Simulated Organization

Assessed asset: NT-SRV-001 | Ubuntu Linux Server

Assessment scope: 12 selected controls across access control, audit, configuration, system integrity, risk assessment, boundary protection, and authentication.

Report date: 29 October 2026

Portfolio assessment conducted in a controlled virtual lab. This document is not a certification, authorization to operate, or independent compliance attestation.

1. Executive Summary

A simulated NIST SP 800-53 control assessment was conducted against a NovaTech Ubuntu Server virtual machine using configuration inspection, Linux commands, functional tests, and a Lynis security audit. Twelve controls were documented in the assessment workbook; all twelve were rated Partially Implemented. This status reflects outstanding governance, operational verification, or remediation evidence, rather than a complete absence of safeguards.

Positive observations included active UFW firewall rules denying unsolicited inbound traffic by default, disabled IP forwarding, functioning ClamAV detection and quarantine during EICAR testing, and installed security updates. Significant issues included broad SSH exposure, password-based SSH authentication, incomplete account governance and log-review processes, and a need to validate sustained malware monitoring after watch-related errors.

The Lynis audit performed 253 checks and reported a hardening index of 67/100. This is a configuration-hardening metric, not a percentage of security or a confirmed vulnerability count.

2. Scope and Methodology

Scope: One lab asset, NT-SRV-001 (Ubuntu Server in UTM). Methods: examine operating-system configuration and audit logs; test permissions and malware detection; inspect network listening services and firewall policy; review Lynis findings. The assessment was limited to available local evidence and does not establish enterprise-wide NIST compliance.

Evidence sources: the reviewed 12-row Excel control tracker and a ZIP containing 62 substantive screenshot files (excluding macOS metadata entries). Later AU-6 and RA-5 screenshots described in conversation were not part of the originally supplied ZIP and should be attached to the final evidence bundle.

3. Control Assessment Register

AC-2 — Account Management

Family: Access Control (AC) | Status: Partially Implemented | Recorded risk: High

Finding: Account management controls are partially implemented. User accounts and group memberships are identifiable and account changes are logged; however, documented account authorization, periodic account reviews, and lifecycle procedures were not evidenced. An HR user was also identified with unrestricted sudo privileges without documented authorization.

Recommended action: Establish formal account management procedures defining account approval, modification, disabling, removal, periodic review, and role-based authorization. Review John's sudo access and remove it if not required and formally approved.

AC-3 — Access Enforcement

Family: Access Control (AC) | Status: Partially Implemented | Recorded risk: High

Finding: HR file permissions restrict Sarah's access. John can access the file through HR group membership. However, John also has unrestricted sudo privileges, creating a potential privilege escalation risk.

Recommended action: Review John's administrative privileges, apply least privilege, and document approved HR access.

AC-6 — Least Privilege

Family: Access Control (AC) | Status: Partially Implemented | Recorded risk: Moderate

Finding: John initially had unrestricted sudo access. Removed John from sudo group and verified administrative access was revoked while HR file access remained functional.

Recommended action: Document role-based access approvals, review other privileged accounts, and perform periodic privilege audits.

AU-2 — Event Logging

Family: Audit and Accountability (AU) | Status: Partially Implemented | Recorded risk: Moderate

Finding: Ubuntu records authentication events, successful sessions, and administrative changes. Formal event selection and review procedures have not been documented.

Recommended action: Document required event types, logging responsibilities, and event selection procedures.

AU-6 — Audit Record Review, Analysis, and Reporting

Family: Audit and Accountability (AU) | Status: Partially Implemented | Recorded risk: Moderate

Finding: Authentication failures and administrative changes were reviewed. Formal recurring review and reporting procedures have not been established.

Recommended action: Establish a regular log review schedule, document review results, and define procedures for reporting suspicious activity.

CM-6 — Configuration Settings

Family: Configuration Management (CM) | Status: Partially Implemented | Recorded risk: Moderate

Finding: Ubuntu firewall and automatic security updates are enabled. SSH password authentication is enabled, SSH access is allowed from any source, and password aging settings permit passwords to remain valid indefinitely. A formally approved configuration baseline has not been verified.

Recommended action: Document and approve a secure configuration baseline. Review SSH access restrictions and password authentication requirements. Verify account authentication policies, monitor configuration changes, and conduct periodic configuration reviews.

CM-7 — Least Functionality

Family: Configuration Management (CM) | Status: Partially Implemented | Recorded risk: Low

Finding: ModemManager and multipathd were running without an identified business need. Both services were stopped, and automatic startup of their services was disabled.

Recommended action: Periodically review enabled services and open ports to ensure only necessary functionality remains active.

SI-2 — Flaw Remediation

Family: System and Information Integrity (SI) | Status: Partially Implemented | Recorded risk: Low

Finding: The Ubuntu server was checked for missing security updates. Available patches were installed, and the updated kernel was verified. Automatic updates were confirmed to be enabled, with daily package checks configured. Five additional updates remain pending due to Ubuntu's phased rollout.

Recommended action: Continue monitoring pending updates and security advisories. Verify that automatic updates run successfully and apply critical security patches within the organization's required timeframe.

SI-3 — Malicious Code Protection

Family: System and Information Integrity (SI) | Status: Partially Implemented | Recorded risk: Low

Finding: ClamAV 1.5.4 was configured with malware scanning and real-time monitoring. Two EICAR test files were successfully detected and automatically quarantined. The monitoring service remained active after both tests. However, watch-related errors appeared in the logs, and the reliability of ongoing monitoring requires further verification.

Recommended action: Investigate the ClamInotif watch errors and confirm continued monitoring after quarantine. Verify that malware signatures update automatically, document routine scanning procedures, and periodically test malware detection and quarantine functionality.

RA-5 — Vulnerability Monitoring and Scanning

Family: Risk Assessment (RA) | Status: Partially Implemented | Recorded risk: Moderate

Finding: Lynis completed 253 security tests with a hardening index of 67. The scan identified recommendations involving password policies, intrusion prevention, audit logging, file integrity monitoring, and permissions. A recurring vulnerability scanning and remediation process has not been verified.

Recommended action: Establish a recurring scanning schedule, verify identified weaknesses, prioritize remediation based on risk, and document corrective actions and follow-up scans.

SC-7 — Boundary Protection

Family: System and Communications Protection (SC) | Status: Partially Implemented | Recorded risk: Moderate

Finding: UFW firewall is active with incoming traffic denied by default. IPv4 and IPv6 forwarding are disabled. SSH is accessible from any source, and password authentication remains enabled.

Recommended action: Restrict SSH access to authorized IP addresses, evaluate disabling password authentication after configuring SSH keys, and periodically review firewall rules.

IA-2 — Identification and Authentication (Organizational Users)

Family: Identification and Authentication (IA) | Status: Partially Implemented | Recorded risk: Moderate

Finding: SSH password authentication is enabled. The assessed account has no password expiration. PAM account lockout was not detected, and Fail2Ban was not available as a service. SSH login time limits are configured. Unique user identification and authentication enforcement require further verification.

Recommended action: Verify unique user accounts and authentication enforcement. Review SSH access restrictions, implement appropriate protection against repeated failed logins, and assess password policies against organizational requirements.

4. Prioritized Plan of Action and Milestones

The following dates are proposed lab remediation targets, not previously approved NovaTech commitments. Risk levels remain provisional pending threat exposure and business impact validation.

Priority	Finding / controls	Proposed action	Target
High	AC-3 / AC-6 privileged access	Confirm privileged access was revoked, re-test least-privilege boundaries, and document approvals.	14 days
Moderate	SC-7 / IA-2 / CM-6 SSH access	Restrict SSH source ranges where practical; validate key-based login before disabling password access.	30 days
Moderate	AU-2 / AU-6 logging governance	Define logged event types, review cadence, escalation owner, and retained review records.	30 days
Moderate	RA-5 recurring assessment	Schedule repeat scans; validate findings; track remediation and retest evidence.	30 days
Moderate	SI-3 malware monitoring	Investigate on-access watch errors; repeat detection/quarantine tests and verify update history.	21 days
Low / review	SI-2 / CM-7 updates and services	Review phased updates, service necessity, and evidence of recurring maintenance.	45 days

5. Evidence and Traceability Notes

Evidence references must be aligned with actual screenshot names before publishing. The reviewed tracker currently contains an incorrect SI-2 reference in the SI-3 evidence field; update it to the 11 SI-3 screenshots. Confirm that AU-6-02 and RA-5-03 are added to their respective folders and that the Lynis report is retained as an original machine-readable artifact.

Screenshot counts are an inventory, not proof that every screenshot meets the full NIST control objective. Where a control has an unresolved issue, retain the Partially Implemented status and the relevant finding.

6. Overall Conclusion

This lab demonstrates practical security control assessment work: account and permission review, audit-log inspection, system hardening, malware scanning and quarantine, firewall and SSH assessment, vulnerability-oriented configuration auditing, and evidence-based reporting. The 12 controls were assessed but not fully implemented. Completing the proposed POA&M and collecting repeat verification evidence would strengthen the security posture and the portfolio narrative.

Appendix: Evidence Inventory

AC-2 Account Managment: 5 screenshot(s)

AC-3 Access Enforcement: 6 screenshot(s)

AC-6 Least Privilege: 5 screenshot(s)

AU-2-Event-Logging: 4 screenshot(s)

AU-6 Audit Review: 1 screenshot(s)

CM-6-Configuration-Settings: 6 screenshot(s)

CM-7-Least-Functionality: 6 screenshot(s)

IA-2: 6 screenshot(s)

Ra-5: 2 screenshot(s)

SC-7: 5 screenshot(s)

SI-2-Flaw-Remediation: 5 screenshot(s)

SI-3: 11 screenshot(s)